

LAB GUIDELINES

Lab 33 — Security Troubleshooting

Maps to CompTIA Server+ objective **4.6 — Given a scenario, troubleshoot security problems** (file integrity, improper privilege escalation, excessive access, app won't load, can't access fileshares, can't open files; causes — open ports, services active/inactive/orphan/zombie, IDS misconfig, anti-malware misconfig, improperly configured local/group policies, improper firewall rules, misconfigured permissions, virus, malware, rogue processes/services, DLP; tools — port scanners, sniffers, telnet clients, anti-malware, antivirus, file integrity — checksums/monitoring/detection/enforcement, user access controls — SELinux, UAC).

Run all commands on <https://killercoda.com/playgrounds/scenario/ubuntu>

Required software (free, apt): nmap, lsof, aide, chkrootkit, clamav, clamav-daemon, auditd

```
apt update && apt install -y nmap lsof aide chkrootkit clamav clamav-daemon auditd
```

Step 1 — Open ports (the first thing an attacker looks at)

```
ss -tulnp
nmap -sT -p- -T4 127.0.0.1 2>/dev/null | head -30
```

Compare against the firewall policy (Lab 9). Any port that listens but the policy doesn't expect → investigate.

Step 2 — Services and processes: active, inactive, orphan, zombie

```
systemctl --type=service --state=running | head
systemctl --type=service --state=failed
ps -eo pid,ppid,state,user,comm | head
ps -eo pid,ppid,state,user,comm | awk '$3=="Z"' # zombies (defunct)
ps -eo pid,ppid,user,comm | awk '$2==1 && $1!=1' | head # reparented to init = orphans
```

Server+ 4.6 vocabulary: **active** (running), **inactive** (stopped), **orphan** (parent died, re-parented to init), **zombie** (terminated but parent hasn't reaped).

Step 3 — Rogue processes / rootkits

```
chkrootkit | head -30
# rkhunter --check --rwo # alternative scanner if installed
```

Indicators of compromise to investigate when you find a suspicious process:

```
PID=$(pgrep -n nginx)
ls -l /proc/$PID/exe # binary path
cat /proc/$PID/cmdline | tr '\0' ' '; echo
cat /proc/$PID/status | head
lsof -p $PID 2>/dev/null | head
```

If /proc/PID/exe points to a deleted binary ((deleted)) — classic IoC for tampered service.

Step 4 — File integrity monitoring with AIDE

```
aideinit -y -f 2>&1 | tail
mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
aide --check 2>&1 | head

# Tamper:
echo "evil line" >> /etc/cron.hourly/0anacron 2>/dev/null
aide --check 2>&1 | head -30
```

This is the **file integrity** workflow from objective 4.6: checksums baseline → monitor → detection → enforcement (alert + remediate).

Step 5 — Improper privilege escalation / excessive access

Hunt for the classic mis-permissions:

```
# World-writable files in /etc:
find /etc -type f -perm -o+w -not -path '/proc/*' 2>/dev/null | head

# SUID/SGID binaries (every new one is suspicious):
find / -xdev \( -perm -4000 -o -perm -2000 \) -type f 2>/dev/null | head

# Sudoers files writable by non-root:
ls -l /etc/sudoers /etc/sudoers.d/* 2>/dev/null
```

Compare current findings to the baseline you snapshot in Lab 17.

Step 6 — Anti-malware scan

```
freshclam 2>&1 | tail
# Scan a test directory (use EICAR test signature for safety):
mkdir -p /tmp/scan && echo 'X50!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*' > /tmp/scan/eicar.txt
clamscan /tmp/scan/ 2>&1 | tail -10
```

ClamAV is the free Linux antivirus. On Windows: Microsoft Defender, vendor EDR.

Step 7 — Cannot access fileshare / cannot open file

Three usual suspects:

```
# 1. Filesystem permission
ls -l /srv/share/          # owner / group / mode
getfacl /srv/share/        # POSIX ACLs

# 2. MAC policy (SELinux / AppArmor)
aa-status 2>/dev/null | head
sestatus 2>/dev/null || true

# 3. Service health
systemctl status smbd
journalctl -u smbd -n 30 --no-pager
```

If file mode looks right but access still fails → check **SELinux** label or **AppArmor** profile. On Windows the equivalent is **UAC** + share permissions + NTFS ACLs.

Step 8 — Firewall rule audit (improperly configured firewall)

```
ufw status numbered
nft list ruleset | head -40
```

Look for: rules that allow ANY → ANY, rules that allow inbound from public IPs to admin ports (22, 3389), rules that override a deny with a later allow.

Step 9 — Local / group policy (Linux ↔ Windows mapping)

Windows GPO setting	Linux equivalent
Password length / complexity	`/etc/security/pwquality.conf` (Lab 20)
Account lockout	`pam_faillock` (Lab 20)
User Rights Assignment	sudoers, group membership
Security Options → audit policy	`auditd` rules (Lab 22)
App locker / SRP	AppArmor / SELinux profiles

Step 10 — Improper IDS / anti-malware config

Signs the security tool itself is misconfigured:

- IDS rules disabled or in detection-only mode in production → log only, never blocks.
- ClamAV definitions out of date (`freshclam` failing).
- AIDE database stored on the same disk it monitors → an attacker can rewrite it.

```
freshclam 2>&1 | tail -3
ls -l /var/lib/aide/aide.db # store the DB off-host if you can
```

Step 11 — DLP (Data Loss Prevention) checks

Server+ 4.6 lists DLP as both cause and tool. From the server side:

```
# auditd rule on the sensitive directory:
auditctl -w /srv/confidential -p rwx -k confidential_access 2>/dev/null
# Watch egress for bulk transfers:
ss -tn | awk '{print $5}' | sort | uniq -c | sort -nr | head
```

Pair with the Lab 13 bandwidth-cap pattern for outbound rsync / scp.

Step 12 — Decision tree

"App won't load / can't open file"	
1. Filesystem perms (ls -l, getfacl)	– Lab 20
2. MAC policy (SELinux / AppArmor)	– Lab 23
3. Service active? Dependencies?	– Lab 31
4. Firewall rule?	– Lab 9
5. File integrity drift? (AIDE)	– this lab
6. Malware / rootkit?	– this lab
7. Local policy / GPO change?	– Lab 20

Free online tools

- **AIDE** — <https://aide.github.io/>
- **ClamAV** — <https://www.clamav.net/>
- **chkrootkit / rkhunter** — <http://www.chkrootkit.org/> , <https://rkhunter.sourceforge.net/>
- **MITRE ATT&CK (TTP reference)** — <https://attack.mitre.org/>

What you learned

- Auditing open ports, listening services, and process states (running / failed / orphan / zombie).
- File-integrity baseline → detection workflow with AIDE.
- Hunting world-writable, SUID, and writable-sudoers misconfigurations.
- Anti-malware scan workflow with ClamAV and the EICAR test signature.
- The triad — filesystem perms, MAC policy, service health — that explains 80 % of "can't open file" tickets.
- Firewall rule, GPO/local-policy, IDS/anti-malware misconfiguration patterns.
- A reusable decision tree for objective 4.6 scenarios.